CSS4005 — Cloud Infrastructure Construction

Lecture 8: Midterm Review and AWS Architecture

Nauruzbayeva Farikha · Lesson 8



Recap — Lesson 7 (Amazon RDS)

- What does RDS manage that a database on EC2 doesn't? (OS and engine patching, automated backups and point-in-time restore, Multi-AZ standby and failover)
- Why is SG-DB's source SG-APP instead of an IP range? (it trusts the app servers wherever they are, and nothing else in the subnet)
- You restore a snapshot. What changes for the app? (a restore creates a **new** instance with a **new** endpoint — the app must be pointed at it)
- Multi-AZ or read replica for "survive an AZ outage"? (Multi-AZ: synchronous standby, automatic failover, same endpoint)

Today’s agenda

- ☐ Midterm review: weeks 1–7 in one pass
- ☐ Review quick checks — test yourself
- ☐ The AWS Well-Architected Framework: six pillars
- ☐ Reading and drawing architecture diagrams
- ☐ Building a three-tier architecture from parts you already know
- ☐ Single points of failure — and how to remove them
- ☐ A design review checklist → today’s practice

The scenario

You know how to launch an EC2 instance, build a VPC, store files in S3, lock things down with IAM and run a database on RDS.

Your manager asks: "Draw me how our app runs on AWS, and tell me what happens if a whole data center goes down." Seven separate skills — one diagram, one answer.

Today: put the pieces together, and learn to defend a design.

Block 1

Midterm review: weeks 1–7

Week 1 — Cloud fundamentals

- **Cloud** = on-demand, self-service, pay-as-you-go access to shared computing resources over the network.
- **Service models:** IaaS (EC2 — you manage the OS), PaaS (RDS — you manage data and access), SaaS (you just use the product).
- **Deployment models:** public, private, hybrid.
- **Global infrastructure:** a **region** is a geographic area; an **Availability Zone** is one or more separate data centers inside it, with independent power and networking.
- **Shared responsibility:** AWS secures *of* the cloud (hardware, facilities); you secure what you put *in* it (data, access, config).

Week 2 — Linux for the cloud

- Every server you launch is (usually) Linux, reached over **SSH** with a key pair.
- Users, groups and **file permissions** (`chmod` , `chown`) — and `chmod 400` on private keys.
- **Packages and services:** `dnf` / `apt` , `systemctl enable --now` .
- Where to look when something breaks: logs (`journalctl` , `/var/log/...`), `ss -tulpn` for listening ports.

> Most cloud troubleshooting is still Linux troubleshooting — on a machine you can't walk up to.

Week 3 — Amazon EC2

- An instance = an **AMI** + an **instance type** + storage + network + a security group.
- **Lifecycle:** stop keeps the EBS root volume (still billed); terminate deletes the instance (and, by default, the root volume).
- **User data** runs once at first boot — bootstrap installs and config.
- **Instance metadata** (IMDSv2) and **instance profiles** give the instance its identity and temporary credentials.
- Pricing models: on-demand, savings plans/reserved, spot.

Week 4 — Networking: VPC

- A **VPC** is your private network in a region; **subnets** live in one AZ each.
- **Public subnet** = route table has `0.0.0.0/0 → Internet Gateway`.
- **Private subnet** = no route from the internet; outbound via a **NAT gateway** in a public subnet.
- **Security groups** — stateful, allow-only, attached to instances.
- **Network ACLs** — stateless, allow and deny, attached to subnets.
- The three-tier lab: web public, app private, DB private — and only the required ports between them.

Week 5 — Storage: EBS and S3

EBS (block)

- A disk for **one** instance, in **one** AZ
- Format, mount, `/etc/fstab` by UUID with `nofail`
- **Snapshots** are incremental, stored in S3
- Restore a snapshot = a new volume (any AZ in the region)

S3 (object)

- Buckets and objects; names are global, data is regional
- **Versioning** protects from overwrite and delete
- **Lifecycle rules** move or expire objects
- **Block Public Access** on by default — keep it on
- **Presigned URLs** for temporary sharing

Week 6 — IAM and cloud security

- **Users** (people), **groups** (permissions by job), **roles** (temporary credentials for services and people).
- Policy evaluation: **explicit deny > explicit allow > implicit deny**.
- **Least privilege:** start from nothing, allow only what the job needs.
- **Instance profiles** instead of access keys on servers.
- Root user: MFA on, no access keys, not for daily work.

Week 7 — Amazon RDS

- Managed relational DB: AWS patches, backs up and fails over; you own access, schema and data.
- **DB subnet group** across two AZs, private subnets, not publicly accessible.
- SG-DB allows the DB port **only from SG-APP**.
- **Backups:** automated (point-in-time) + manual snapshots; a restore is a **new** instance.
- **Multi-AZ** for availability; **read replicas** for read scaling.

How the midterm checks this

- The format, date and weighting are **as announced by your instructor**.
- Expect to **explain**, not just recall: "why this, not that?"
- Expect to **read or draw a diagram** — the same kind we build today.
- Expect "what if" questions: a subnet has no route, an SG is too open, an AZ fails, a key leaks.

Best preparation: the labs and practices from weeks 3–7, and being able to say **why** each step was there.

Block 2

Review quick checks

Quick check 1

An EC2 instance in a subnet can't reach the internet, even though its security group allows all outbound traffic. Name two things to check.

The subnet's route table (is there `0.0.0.0/0` to an IGW, or to a NAT gateway for a private subnet?), and whether the instance has a public IP (for a public subnet). Also check the network ACL.

Quick check 2

You stopped an instance to save money. What are you still paying for?

EBS volumes (including the root volume), snapshots, and any public IPv4 or Elastic IP address that stays allocated.

Quick check 3

Your EBS volume is in `us-east-1a`. You need the same data on an instance in `us-east-1b`. How?

Take a snapshot, then create a new volume from it in `us-east-1b` and attach it there. A volume can't be attached across AZs.

Quick check 4

A user's policy allows `s3:*` on a bucket, and a second policy denies `s3:DeleteObject`. Can the user delete objects?

No. An explicit deny always beats an allow.

Quick check 5

Someone deletes an object by mistake in a bucket with versioning on. Is it gone?

No. S3 adds a delete marker; the previous version is still there. Deleting the delete marker brings the object back.

Quick check 6

Your app should reach the database, but nothing else should. How do you write the security group rule?

On SG-DB: allow the DB port (e.g. 5432 or 3306) with the **source = the app tier's security group**, not a CIDR range, and the DB not publicly accessible.

Block 3

The AWS Well-Architected Framework

What it is

- AWS's set of **design principles and questions** for judging whether a workload is built well.
- Organised into **six pillars**. A good design makes conscious trade-offs between them — it rarely maximises all six.
- Free to read: the Well-Architected Framework whitepaper, and the Well-Architected Tool in the AWS console for structured reviews.

You already applied most of it: Multi-AZ, least privilege, deleting unused resources — today we give those habits names.

The six pillars

Pillar	The question it asks
Operational excellence	Can we run, monitor and change it safely?
Security	Is data and access protected at every layer?
Reliability	Does it keep working — and recover — when parts fail?
Performance efficiency	Are we using the right resources, and adapting as demand changes?
Cost optimization	Are we paying only for what delivers value?
Sustainability	Are we minimising the environmental impact of running it?

One example per pillar

- **Operational excellence:** bootstrap servers with user data (or scripts) instead of clicking — repeatable and reviewable.
- **Security:** instance profile instead of access keys; SG-DB only from SG-APP; Block Public Access on S3.
- **Reliability:** two AZs for the app tier; RDS Multi-AZ; automated backups with a tested restore.
- **Performance efficiency:** pick the instance type and EBS volume type for the workload; serve static files from S3.
- **Cost optimization:** stop or delete what's idle; lifecycle rules to cheaper S3 classes; right-size instances.
- **Sustainability:** right-size and turn off unused resources — less waste is also less energy.

Quick check

You turn on RDS Multi-AZ. Which pillar does that serve, and what does it cost you?

Reliability. The trade-off is cost: Multi-AZ runs a standby instance, so you pay for roughly a second DB instance.

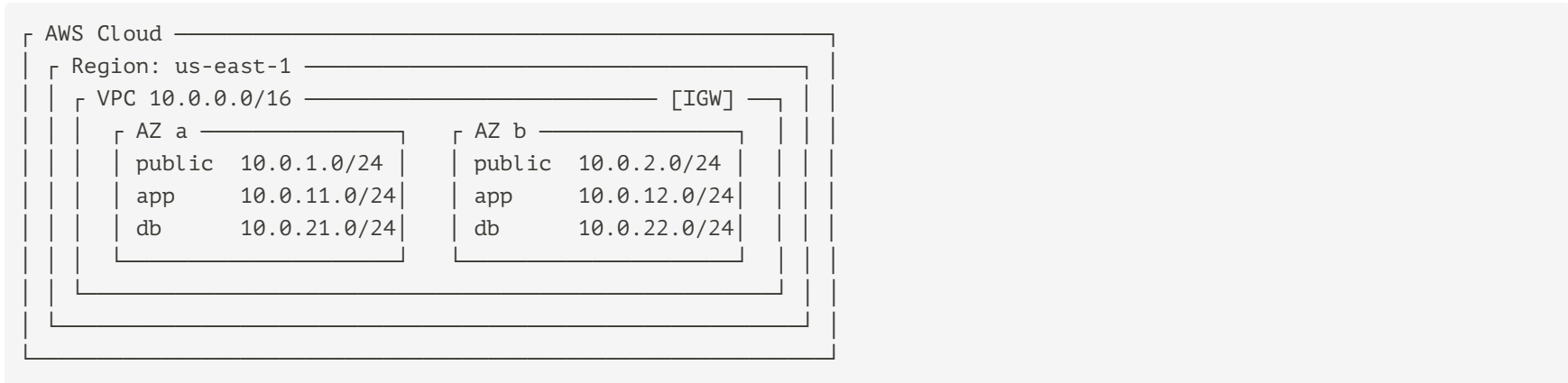
Block 4

Reading and drawing architecture diagrams

Diagram conventions

- **Nested boxes** show scope, outside in: AWS Cloud → **Region** → **VPC** → **Availability Zone** → **Subnet**.
- Public and private subnets are usually coloured differently (AWS's set uses green for public, blue for private).
- **Service icons** come from the official AWS Architecture Icons set — available in diagrams.net (draw.io) under "AWS".
- **Arrows** show request flow; label them with port/protocol when it matters (e.g. `HTTPS 443`, `5432`).
- Things outside the VPC (S3, IAM) sit outside the VPC box, inside the region or cloud.

The skeleton every diagram starts with



Two AZs, three subnet tiers in each — before a single server is drawn.

What a reviewer looks for in a diagram

- Is every subnet clearly **public or private** — and does that match its route table?
- Is anything that shouldn't be reachable from the internet **in a private subnet**?
- Does every tier exist in **more than one AZ**?
- Are the **arrows and ports** consistent with the security groups?
- Where is **data stored**, and how is it backed up?

Block 5

Building a three-tier architecture

Step 1 — Network

- One VPC, **two AZs**.
- In each AZ: a **public** subnet, an **app** (private) subnet, a **DB** (private) subnet.
- An **Internet Gateway**; public route table `0.0.0.0/0 → IGW`.
- A **NAT gateway** in a public subnet, so private instances can download updates without being reachable from the internet.

For high availability, production designs often put one NAT gateway per AZ — a single NAT gateway is itself a single point of failure.

Step 2 — Entry point and app tier

- Users don’t connect to individual servers. They connect to a **load balancer** in the public subnets (Application Load Balancer — **next week’s topic**).
- The **app servers** (EC2) run in the **private app subnets of both AZs** — no public IPs.
- Each server has an **instance profile** (IAM role) for the AWS access it needs — e.g. read from one S3 prefix.
- Servers are built the same way every time: same AMI, same user data.

Step 3 — Data tier and static files

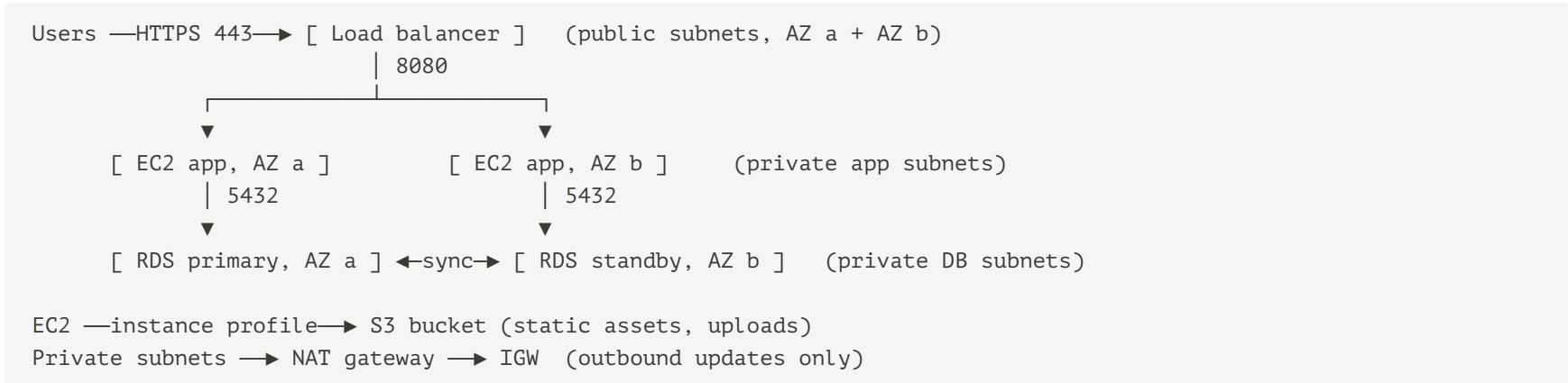
- **RDS** in a DB subnet group across both AZs, **Multi-AZ** on, not publicly accessible, encrypted, automated backups on.
- **S3** for static assets and uploads — Block Public Access on; serve through the app or presigned URLs.
- **EBS** only for what must live on a server's disk; snapshots for backup.

Step 4 — Security groups, chained

Security group	Inbound rule	Source
SG-LB	443 (HTTPS), 80 → redirect	`0.0.0.0/0`
SG-APP	app port (e.g. 8080)	**SG-LB**
SG-DB	5432 / 3306	**SG-APP**

- Each tier only trusts the tier in front of it.
- No SSH from the internet: use Session Manager or a bastion if you must reach a private instance.
- Network ACLs stay at the default unless you need an extra subnet-level deny.

The finished picture



Every box is something you have already built in a lab — except the load balancer, which is next week.

Block 6

Single points of failure

Find the single point of failure

Component	If it's alone…	How to remove the SPOF
One EC2 instance	Instance fails → site down	≥ 2 instances in 2 AZs behind a load balancer
One AZ	AZ outage → everything down	Every tier in ≥ 2 AZs
Single-AZ RDS	DB host or AZ fails → no data	RDS Multi-AZ
One NAT gateway	Its AZ fails → private subnets lose outbound	One NAT gateway per AZ
Data on one EBS volume	Volume lost → data lost	Snapshots; data in RDS/S3

Quick check

AZ `a` goes down in the finished picture. Walk through what happens to a user's request.

The load balancer stops sending traffic to the app server in AZ a and uses AZ b. RDS fails over to the standby in AZ b (same endpoint, a short interruption). Users see at most a brief blip — if every tier really is in both AZs.

Design review checklist

- ☐ Every tier in **two or more AZs**?
- ☐ Only the entry point in **public** subnets?
- ☐ SGs **chained** tier to tier, DB never open to `0.0.0.0/0`?
- ☐ **IAM roles** instead of access keys on servers?
- ☐ **Backups** on, and a restore you've actually tried?
- ☐ **Encryption** at rest for EBS, RDS and S3?
- ☐ Cost: anything running that doesn't need to?

Block 7

Today’s practice

Today’s practice — design and defend

In pairs, no AWS needed:

1. Read the scenario: a university course-registration app
2. Draw the AWS architecture (diagrams.net or paper)
3. Fill a design table: component → pillar → failure it handles
4. Answer the instructor’s **failure walk-through** live

What we check, orally:

- Two AZs for every tier
- Public vs private subnets, with routes
- Chained security groups
- Where the data lives and how it’s backed up
- What happens when *this* fails

Stretch: estimate the monthly cost in the AWS Pricing Calculator — no login needed.

By the end of this lesson, you should be able to

- ☐ Explain the core idea of each topic from weeks 1–7 in one or two sentences
- ☐ Name the six Well-Architected pillars and give an example of each
- ☐ Read an AWS architecture diagram: region, VPC, AZs, subnets, services, flows
- ☐ Draw a three-tier architecture across two AZs from known components
- ☐ Find single points of failure in a design and remove them

Before next lecture

- ☐ Prepare for the midterm as announced by your instructor
- ☐ Redraw today’s three-tier diagram from memory, with ports on the arrows
- ☐ Note every place in your design where you wrote "load balancer" — that’s next week

Next week fills in the box we left as a placeholder: the load balancer, and how to add and remove servers automatically.

Next lecture

Load Balancing and Auto Scaling — the entry point and the self-healing fleet behind it.